

无线通信安全历年题与模拟题合并版

历年题答案 + 三套高命中模拟题

依据课件、课堂口径与往年题型整理

2026 年 6 月 23 日

目录

第一部分：历年题答案	4
1. (10 分) 重放攻击应对策略 3 种	4
2. (10 分) WEP 的功能原理，安全性缺陷	4
3. (10 分) 安全域，接入认证和 PIN 码认证是否同一安全域	5
4. (10 分) WCDMA：为什么每换一个基站就要重新认证	6
5. (10 分) TETRA 空口加密和端到端加密的密钥流同步区别	6
6. (15 分) 5G 匿名的新方法，分析优缺点	7
7. (15 分) LTE 密钥管理，能否实现前向安全和后向安全	8
8. (20 分) AES-CBC 中 IV 级联密文传输，通信密钥提前通过安全信道交换，请提建议	9
第二部分：模拟题精压版	11
模拟题精压版使用方法	11
模拟题 A：高概率换角度卷	12
1. (10 分) 某无线接入协议允许终端和网络协商加密算法，但算法列表和最终选择结果没有完整性保护。请分析风险并给出改进建议。	12
2. (10 分) 说明 WPA2/802.11i 中四次握手的作用。为什么说 AES-CCMP 比“单纯共享一个长期密码后直接加密”更安全?	12

3. (10 分) 请按“攻击过程”分析 GSM 伪基站为什么能诱导用户暴露 IMSI, 并说明 3G/4G/5G 分别如何缓解。 12
4. (10 分) WCDMA 中 f8 和 f9 分别解决什么安全问题? 如果只启用 f8 加密而不启用 f9 完整性, 会留下什么缺陷? 13
5. (10 分) TETRA 专网中, 为什么端到端加密不能替代空口加密? 请结合调度、组呼和网络管理场景说明。 13
6. (15 分) 说明 LTE 从接入请求到安全模式完成的大致安全建立过程。为什么要把 NAS 安全和 AS 安全分开? 13
7. (15 分) 5G 网络切片为什么需要二次认证? SBA 和 SEPP 分别带来什么新的安全要求? 14
8. (20 分) 某工业无线控制系统要求低时延和高可靠, 只打算“预共享密钥 + 加密数据”, 不做双向认证、完整性保护和密钥更新。请设计更完整的安全方案。 14

模拟题 B: 综合押题卷 15

1. (10 分) 某协议把“是否启用完整性保护”作为普通明文字段发送。攻击者若把该字段改成“不启用”, 会造成什么问题? 15
2. (10 分) 比较 WPA2-PSK 与 WPA3-SAE 在口令安全上的差异。为什么 SAE 更适合抵抗离线字典攻击? 15
3. (10 分) TMSI/GUTI 这类临时身份能否彻底解决用户跟踪问题? 请分析原因。 . . . 15
4. (10 分) WCDMA AKA 中 UE 为什么要检查 AUTN 中的 MAC 和 SQN? 如果只检查 MAC 不检查 SQN 会怎样? 16
5. (10 分) TETRA 组呼业务中, 为什么需要考虑组密钥管理? 组成员变化会带来什么安全问题? 16
6. (15 分) 为什么说 LTE 用户面完整性保护不足是一个安全缺口? 5G 在哪些场景下更需要开启用户面完整性? 16
7. (15 分) 5G 服务化核心网中, 若某网络功能 NF 的 API 鉴权配置错误, 可能造成哪些风险? 应如何防护? 17
8. (20 分) 某无线系统准备把“身份、算法、序列号、密文”分别独立处理: 身份明文发、算法明文协商、序列号不认证、数据只加密。请从安全目标角度整体评价并重构报文保护格式。 17

模拟题 C: 真题同章换问法卷 18

1. (10 分) 在无线认证协议中, 为什么仅依靠“用户名 + 固定口令/固定响应值”容易受到重放攻击? 请给出三类防护办法。 18
2. (10 分) 某 WLAN 方案使用 RC4 流密码和 CRC 校验, 并把 IV 明文放在数据帧中。请评价其安全性, 并说明应如何改进。 18
3. (10 分) 从移动通信安全体系看, 用户域安全和接入域安全有什么区别? 请以 PIN 认证和 AKA 认证为例说明。 18
4. (10 分) WCDMA 中 UE 如何通过 AUTN 验证网络? 为什么安全上下文失效或跨服务区移动时需要重新建立安全? 19

5. (10 分) TETRA 中空口加密和端到端加密都可能使用密钥流。为什么二者的同步对象不同?	19
6. (15 分) 5G 为什么要用 SUCI 隐藏 SUPI? 请说明基本流程, 并分析它能解决什么问题、不能解决什么问题。	20
7. (15 分) LTE 为什么采用分层密钥管理? 请说明 KASME、NAS 密钥、KeNB 与切换密钥更新的关系。	20
8. (20 分) 某方案使用 AES-CBC 加密无线数据, IV 明文随密文发送, 双方密钥由线下安全方式预先配置。请从机密性、完整性、防重放和密钥管理角度评价, 并给出改进方案。	20

第一部分：历年题答案

1. (10 分) 重放攻击应对策略 3 种

答：

重放攻击是指攻击者截获一次合法通信消息后，在之后重新发送该旧消息，使接收方误认为它是新的合法消息。应对重放攻击的核心是保证消息的新鲜性。常用策略有以下三种。

第一，使用随机数挑战-应答机制。通信一方先发送一次性随机数 nonce 或 RAND，另一方必须把该随机数参与 MAC、签名或密钥计算并返回。由于每次认证过程中的随机数不同，攻击者重放以前的响应不能通过新的挑战。课件中的 GSM 鉴权、WCDMA AKA、LTE EPS-AKA、5G-AKA 都使用 RAND 作为认证挑战。

第二，使用序列号或计数器机制。发送方在每条消息中加入单调递增的序列号、SQN 或 COUNT，并将其纳入完整性保护。接收方记录已接收的最大序列号，或维护重放窗口，拒绝重复、过旧或异常乱序的消息。例如 WCDMA AKA 中 AUTN 携带 SQN 信息，UE 检查 SQN 是否在合理范围；LTE/5G 的信令和用户面可用 COUNT、承载号和方向等参数参与完整性计算。

第三，使用时间戳或有效期机制。发送方在消息中加入时间戳或过期时间，并通过 MAC 或数字签名保护。接收方检查消息是否处在允许时间窗口内，若超时则拒绝。该方法适用于双方时钟同步较好的系统，但在无线网络中需要考虑时钟误差和传输时延。

综上，随机数、序列号和时间戳都可以防重放，但这些字段必须被 MAC、签名或认证加密保护，否则攻击者可以修改这些字段绕过检查。

2. (10 分) WEP 的功能原理，安全性缺陷

答：

WEP 是早期 IEEE 802.11 WLAN 中的安全机制，全称 Wired Equivalent Privacy，目标是让无线局域网获得类似有线网络的保密性。按课件口径，WEP 主要涉及 RC4、共享密钥、24 bit IV 和 CRC-32/ICV。

WEP 的基本原理如下。发送方首先选取 24 bit 初始向量 IV，将 IV 与共享 WEP Key 拼接后输入 RC4，生成密钥流：

$$\text{KeyStream} = \text{RC4}(\text{IV} \parallel K).$$

然后发送方对明文计算 CRC-32，得到完整性校验值 ICV，并将明文和 ICV 一起与密钥流异或，得到密文：

$$C = (P \parallel \text{ICV}) \oplus \text{KeyStream}.$$

接收方收到 IV 和密文后，使用相同共享密钥和 IV 生成同样的 RC4 密钥流，异或恢复明文和 ICV，再重新计算 CRC-32 判断数据是否出错。

WEP 的安全缺陷主要有以下几点。

第一，IV 太短。WEP 的 IV 只有 24 bit，在高流量无线网络中很容易重复。由于 RC4 是流密码，同一密钥流重复使用会严重破坏机密性，攻击者可以利用多个密文之间的关系恢复明文或密钥信息。

第二，静态共享密钥管理困难。多个用户长期使用同一个共享密钥，一旦密钥泄露，整个 WLAN 都会受到影响，且密钥更新和撤销困难。

第三，CRC-32 不是安全 MAC。CRC-32 只是检错码，不带密钥，不能抵抗恶意篡改。攻击者可以有目的地修改密文，并调整校验值，使接收方难以发现。

第四，共享密钥认证方式会泄露信息。AP 发送挑战明文，客户端返回加密后的挑战密文，攻击者可同时获得明文和密文，从而得到一段密钥流，为后续伪造提供条件。

第五，WEP 缺少可靠的防重放机制，不能有效阻止旧帧被重复发送。

因此，WEP 只能提供很弱的安全性，后来被 WPA/TKIP、802.11i/WPA2 的 AES-CCMP 以及 WPA3-SAE 等机制替代。

3. (10 分) 安全域，接入认证和 PIN 码认证是否同一安全域

答：

安全域是课件中用来划分移动通信安全机制的概念，可以理解为：在一定安全边界内，具有相近安全需求并采用相应安全机制的一组实体。3G 安全体系通常从接入域、网络域、用户域、应用域，以及安全可见性和可配置性来描述。

移动通信系统中常见的安全域包括以下几类。

第一，接入域安全。接入域保护 UE 安全接入移动网络，主要包括用户身份机密性、用户认证、网络认证、密钥协商、空口加密、完整性保护和设备鉴定等。GSM 鉴权、WCDMA AKA、LTE EPS-AKA、5G-AKA 都主要属于接入域安全。

第二，网络域安全。网络域保护运营商网络实体之间的通信，包括核心网节点之间的认证、信令机密性、完整性保护和攻击监测。例如网络节点之间的安全传输、漫游边界保护、5G 的 SEPP 等可归入网络域安全。

第三，用户域安全。用户域安全保护用户、SIM/USIM 和移动终端之间的本地安全，包括 PIN 码认证、USIM 与终端之间的认证、终端本地访问控制等。

第四，应用域安全。应用域安全保护应用层业务，例如网页、支付、即时通信和业务平台的端到端安全。

接入认证和 PIN 码认证不属于同一安全域，但二者都属于广义的“认证”机制。

接入认证属于接入域安全。它解决的是“用户或终端能否接入移动网络、接入的网络是否真实、双方如何建立会话密钥”的问题，参与实体通常是 UE、USIM、服务网络和归属网络。比如 WCDMA AKA 中，UE 通过 AUTN 验证网络，网络通过 RES/XRES 验证用户。

PIN 码认证属于用户域安全。它解决的是“当前使用 SIM/USIM 的人是否有权使用这张卡”的本地访问控制问题，参与实体主要是用户和 SIM/USIM。即使还没有接入移动网络，PIN 码认证也可以在本地发生。

因此，二者共同点是都在确认身份，但安全目标、参与实体和保护范围不同。接入认证属于接入域，PIN 码认证属于用户域。

4. (10 分) WCDMA: 为什么每换一个基站就要重新认证

答:

严格来说, WCDMA 中并不是每换一个基站都一定要完整重新执行 AKA 认证。WCDMA 中无线接入网存在 RNC 等控制实体, 切换时是否重新认证取决于安全上下文是否仍然有效、是否能够安全转移以及网络策略要求。若题目这样问, 可以从“切换时为什么需要重新确认或更新安全上下文”的角度回答, 避免绝对化。

首先, 移动终端换基站时, 服务小区和无线链路发生变化, 新接入点是否可信、是否拥有正确安全上下文需要确认。无线信道开放, 攻击者可能搭建伪基站诱导 UE 接入, 因此切换时必须保证 UE 与合法网络之间的认证关系仍然成立。

其次, 切换过程中需要保证通信机密性和完整性的连续性。WCDMA AKA 由认证向量 $AV = (RAND, XRES, CK, IK, AUTN)$ 支持, 其中 CK 用于加密, IK 用于完整性保护。如果 UE 切换到新基站或新服务网络后不能正确获得或使用安全上下文, 可能导致加密中断、完整性保护失效或使用错误密钥。

再次, 重新认证或更新安全上下文可以避免长期使用旧密钥。如果源基站或旧安全上下文已经泄露, 继续使用旧密钥会影响后续通信安全。因此在跨域切换、上下文失效、密钥过期、网络策略要求或无法安全转移上下文时, 需要重新认证或重新建立安全上下文。

但是, 如果在同一安全上下文范围内切换, 源网络和目标网络之间能够安全转移上下文, 且 CK/IK 等安全参数仍然有效, 则不一定需要每次完整重新 AKA。这样可以减少切换时延和信令开销。只有在跨域切换、上下文失效、网络策略要求、密钥过期或安全上下文无法可信转移时, 才更需要重新认证或重新建立安全上下文。

因此, 换基站时重新认证或更新安全上下文的目的, 是保证新接入点合法、密钥新鲜、加密和完整性保护连续, 并防止伪基站、重放攻击和旧密钥泄露影响后续通信。

5. (10 分) TETRA 空口加密和端到端加密的密钥流同步区别

答:

TETRA 的空口加密和端到端加密都可以采用流密码思想, 即发送方和接收方必须生成相同的密钥流才能正确加解密。但二者的保护范围、同步对象和同步方式不同。

空口加密保护的是移动台 MS 与基站或 SwMI 之间的无线链路。加密和解密终结点在 MS 和网络接入侧。按课件口径, TETRA 空口加密涉及 SCK、DCK、CCK 等密钥以及 KSG 密钥流生成器。Class 1 不使用空口加密, Class 2 使用 SCK 静态密钥, Class 3 使用 DCK/CCK 等动态或通用密钥, 安全性更强。空口加密的密钥流同步通常依赖 TETRA 系统本身的空口帧结构, 例如帧号、时隙、IV、广播同步信息等。由于空口链路由系统统一控制, MS 和 SwMI 可以根据相同的系统同步参数驱动 KSG, 产生相同密钥流。空口加密主要防止攻击者在无线信道上监听、分析或操纵控制/业务信息, 但网络接入侧可以解密并处理数据。

端到端加密保护的是通信双方终端之间的业务内容。加密和解密终结点在两个终端, 中间的基站、SwMI 和交换网络只转发密文, 不能获得业务明文。由于端到端通信可能经过多个网络节点, 不能只依赖某一段空口帧结构同步。端到端加密通常通过同步帧或业务数据中的同步

字段传递 SV、Key ID、同步计数等参数，使接收终端知道使用哪把端到端密钥和哪个同步值，从而生成与发送端相同的密钥流。

二者区别可概括如下：

项目	空口加密	端到端加密
保护范围	MS 到基站/SwMI 的无线链路	终端到终端的业务内容
同步依据	空口帧号、IV、时隙、系统同步信息	同步帧、SV、Key ID、端到端计数
网络能否解密	网络接入侧可以解密	中间网络不能解密业务内容
主要目的	防止空口监听和操纵	防止网络内部或传输链路泄露内容

因此，空口加密是链路级保护，密钥流同步依赖空口系统同步；端到端加密是业务级保护，密钥流同步依赖终端之间传递的端到端同步信息。

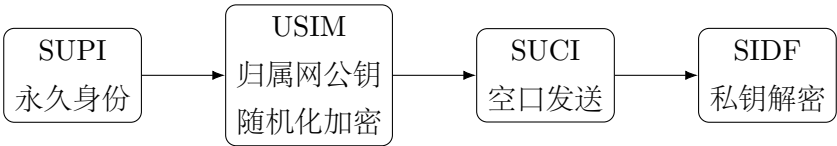
6. (15 分) 5G 匿名的新方法，分析优缺点

答：

5G 匿名的新方法主要是使用 SUCI 隐藏用户永久身份 SUPI。按课件口径，SUPI 是用户永久身份，类似以前的 IMSI；SUCI 是 Subscription Concealed Identifier，即使用归属网公钥隐藏后的用户身份。

5G 以前的系统主要依赖临时身份保护用户隐私，例如 GSM 的 TMSI、3G 的 P-TMSI、LTE 的 GUTI 和 S-TMSI。但在首次接入、临时身份失效或伪基站主动请求身份时，IMSI 仍可能明文发送，从而导致 IMSI catcher 和位置跟踪问题。

5G 中，UE/USIM 使用归属网公钥对 SUPI 进行随机化加密，生成 SUCI，然后在空口发送 SUCI。归属网中的 SIDF 使用对应私钥解密 SUCI，恢复 SUPI。这里的“随机化”很重要：同一个 SUPI 多次生成的 SUCI 应不同，否则仍可能被链接跟踪。



该方法的优点如下。

第一，避免永久身份明文暴露。攻击者即使监听空口，也只能得到 SUCI，不能直接得到 SUPI，从而缓解 IMSI catcher 类攻击。

第二，降低用户可跟踪性。SUCI 应采用随机化加密，同一个 SUPI 每次生成的 SUCI 不同，攻击者难以通过相同标识判断是否为同一用户。

第三，适合首次接入场景。即使 UE 没有可用临时身份，也不必明文发送永久身份。

第四，只有归属网可以恢复真实身份。服务网和攻击者无法直接解密 SUPI，增强了归属网对用户身份的控制。

该方法也存在一定局限。

第一，公钥加密和密钥管理增加了实现复杂度，对 USIM、终端和归属网的密钥配置提出要求。

第二，UE 必须持有正确的归属网公钥。如果公钥配置错误、过期或被替换，会影响身份保护。

第三，SUCI 不能解决所有跟踪问题。攻击者仍可能通过无线指纹、寻呼模式、临时身份变化、错误消息差异和位置更新行为等方式进行关联。

第四，随机化必须正确。如果 SUCI 加密缺少随机性，或者随机数质量差，同一用户可能生成可链接的 SUCI，仍会被跟踪。

综上，5G 的 SUCI 机制比传统临时身份机制更强，能在首次接入时隐藏永久身份，是 5G 匿名保护的重要增强。但它不是完整匿名，还需要配合临时身份更新、统一错误消息、寻呼保护和 AKA 隐私增强。

7. (15 分) LTE 密钥管理，能否实现前向安全和后向安全

答：

LTE 采用分层密钥管理，课件重点是 NAS/AS 分层、eNB 不完全可信、不同用途密钥分离，以及移动切换中的密钥更新。其大致密钥派生关系为：

$$K \rightarrow CK, IK \rightarrow K_{ASME} \rightarrow K_{NASenc}, K_{NASint}, K_{eNB} \rightarrow K_{RRCenc}, K_{RRCint}, K_{UPenc}.$$

其中， K 是 USIM 与归属网共享的长期密钥； CK/IK 由 AKA 产生； K_{ASME} 是 EPS 安全锚密钥；NAS 密钥保护 UE 与 MME 之间的 NAS 信令； K_{eNB} 以及下级 RRC/UP 密钥保护 UE 与 eNB 之间的接入层信令和用户面。这样做的意义是密钥隔离：eNB 只掌握接入层密钥，不掌握 NAS 层密钥。

在 LTE 切换场景中，前向安全和后向安全含义如下。

后向安全是指目标 eNB 不能获得源 eNB 过去使用的密钥，因此不能解密 UE 在源 eNB 下的历史通信。前向安全是指源 eNB 不能获得目标 eNB 将来使用的密钥，因此不能解密 UE 切换到目标 eNB 后的未来通信。

LTE 对后向安全支持较好。目标 eNB 使用从当前安全上下文派生的新 K_{eNB}^* ，而不是直接获得源 eNB 的旧密钥。只要密钥派生函数是单向的，目标 eNB 无法从新密钥反推出源 eNB 过去使用的密钥，因此不能解密过去通信。

LTE 对前向安全的实现较复杂，不能简单认为完全实现。在某些切换方式中，源 eNB 可能参与目标 eNB 密钥派生，或者把切换密钥材料传给目标 eNB。如果源 eNB 已被攻破，攻击者可能获得目标 eNB 本轮使用的密钥，从而破坏本次切换后的前向安全。

为缓解该问题，LTE 引入 NH (Next Hop) 和 NCC (NH Chaining Counter)。NH 由 MME 和 UE 从 K_{ASME} 派生，源 eNB 无法自己计算新的 NH。后续切换可使用 NH 链式更新密钥，使源 eNB 逐渐失去对未来密钥的了解。

因此，LTE 通过分层密钥、KDF、NH/NCC 等机制可以较好地实现后向安全，并逐步增强前向安全。但如果源 eNB 在某些切换过程中掌握目标密钥材料，或源 eNB 已经被攻破，则本轮切换的前向安全可能受到影响。为提高安全性，应结合 NH/NCC、周期性重新认证、密钥刷新和安全上下文更新。

8. (20 分) AES-CBC 中 IV 级联密文传输，通信密钥提前通过安全信道交换，请提建议

答：

题目描述的方案可以理解为：通信双方提前通过安全信道共享对称密钥 K ，发送方使用 AES-CBC 加密消息，并将初始向量 IV 与密文级联发送：

$$IV \parallel C_1 \parallel C_2 \parallel \cdots \parallel C_n.$$

该方案能够提供一定机密性，但作为完整安全通信方案仍不充分。

首先，该方案的优点是使用了标准分组密码 AES，算法本身安全性较高；使用 CBC 模式而非 ECB 模式，可以避免相同明文块直接产生相同密文块；通信密钥提前通过安全信道交换，也避免了密钥在开放无线信道中明文传输。按课件说法，CBC“安全性好于 ECB，但要配完整性保护”。

但是，该方案存在以下主要问题。

第一，AES-CBC 只提供机密性，不能提供完整性保护。攻击者虽然可能看不懂密文，但可以修改 IV 或密文块，使解密后的明文发生变化。接收方如果没有 MAC 或认证标签，无法判断密文是否被篡改。

第二， IV 的生成和保护存在要求。CBC 模式要求同一密钥下每次加密使用随机、不可预测且不重复的 IV 。 IV 可以明文传输，但必须被完整性保护。若攻击者修改 IV ，会直接影响第一块明文解密结果。

第三，该方案缺少报文级来源认证。虽然题目说通信密钥已提前通过安全信道交换，若该安全信道本身已经完成身份认证，则初始密钥分发阶段身份问题较小；但后续单条报文本身仍缺少 MAC 或认证标签，接收方无法确认该密文确实来自合法发送方，也无法发现中间人插入或替换密文。

第四，该方案缺少防重放机制。攻击者可以截获某次合法通信中的 $IV \parallel C$ ，之后原样重放。若接收方不检查序列号、时间戳或 nonce，就可能接受旧消息。

第五，长期预共享密钥存在风险。如果长期直接使用同一通信密钥加密大量数据，一旦密钥泄露，历史和未来通信都可能受到影响，也增加了密码分析风险。

第六，CBC 需要填充。如果系统对填充错误、解密错误和认证错误返回不同提示，可能产生 padding oracle 攻击。

针对上述问题，可以提出以下改进建议。

第一，增加完整性保护。推荐采用 Encrypt-then-MAC，即先用 AES-CBC 加密，再对身份、方向、算法标识、序列号、 IV 和密文整体计算 HMAC 或 CMAC。接收方必须先验证 MAC，验证通过后再解密。

第二，更推荐直接采用认证加密模式，例如 AES-GCM 或 AES-CCM。这类模式同时提供机密性、完整性和认证标签，能减少 CBC 填充和 MAC 组合不当带来的风险。

第三，加入防重放字段。每条消息应包含序列号、COUNT、时间戳或 nonce，并把这些字段纳入 MAC 或认证标签。接收方维护重放窗口，拒绝重复、过期或异常乱序消息。

第四，规范 IV 生成。IV 应由安全随机数生成器产生，同一密钥下不重复且不可预测。IV 可以与密文一起发送，但必须被 MAC 或认证标签保护。

第五，进行密钥分离。不能用同一个密钥同时做加密和 MAC。应通过 KDF 从预共享主密钥派生不同用途密钥：

$$K_{enc}, K_{mac}, K_{send}, K_{recv} = KDF(K_{master}, context).$$

这样可以区分加密密钥、完整性密钥以及不同通信方向的密钥。

第六，建立会话密钥更新机制。预共享密钥不宜长期直接用于大量数据加密，可以用预共享密钥完成初始认证，再结合双方随机数派生会话密钥，并定期更新。

第七，统一错误消息。MAC 失败、填充失败、解密失败不应返回可区分错误，避免 padding oracle 和侧信道攻击。

推荐的改进方案为：

$$K_{enc}, K_{mac} = KDF(K_{master}, R_A, R_B, context),$$

$$C = AES-CBC_{K_{enc}}(IV, P),$$

$$T = HMAC_{K_{mac}}(ID_A, ID_B, Alg, Seq, IV, C).$$

最终发送：

$$Seq \parallel IV \parallel C \parallel T.$$

接收方先检查 Seq 是否新鲜，再验证 T，最后解密。更简单可靠的方案是直接使用 AES-GCM 或 AES-CCM，将身份、方向、算法标识和序列号作为 AAD，把密文和认证标签一起发送。

综上，原方案有一定机密性基础，但缺少完整性、报文级来源认证、防重放和密钥更新。改进时应采用认证加密或加密后 MAC，保护 IV 和密文，引入序列号/nonce，进行密钥分离和会话密钥更新。

第二部分：模拟题精压版

使用方法

这一版把模拟题压成三套，每套仍按 10 + 10 + 10 + 10 + 10 + 15 + 15 + 20 = 100 分设计。A、B 两套偏换角度分析；C 套专门按真题章节和分值出“同章换问法”，更接近考试手感。真题部分已经单独放在前面，模拟题主要练“看到陌生题如何套安全目标答”。

题号	避开真题后的押题方向	答题核心
1	协议新鲜性/降级/安全目标	不只写防重放，要会写完整性、算法协商、MAC 保护。
2	WLAN 后续机制	少背 WEP 原题，多会写 WPA2 四次握手、CCMP、WPA3/SAE。
3	GSM/伪基站/身份隐私	从“安全域”换成攻击链分析。
4	WCDMA 完整性/f8/f9	从“重新认证”换成信令完整性和算法分工。
5	TETRA 业务场景	从“同步区别”换成空口、端到端、组密钥为什么都要有。
6	LTE 安全建立/用户面缺口	从“前向后向安全”换成 NAS/AS 流程、UP 完整性缺口。
7	5G 切片/SBA/SEPP	从“匿名”换成 5G 核心网和垂直行业安全。
8	综合设计/方案分析	不押同一个 CBC 原题，练通用“机密性 + 完整性 + 认证 + 防重放 + 密钥更新”。

模拟题 A：高概率换角度卷

1. (10 分) 某无线接入协议允许终端和网络协商加密算法，但算法列表和最终选择结果没有完整性保护。请分析风险并给出改进建议。

对应章节/考点：第二讲密码学基础 + 第三讲无线安全威胁；避开真题“重放三策略”，改考降级攻击和完整性保护。

答案要点：

问题不是“有没有加密”，而是攻击者可在协商阶段篡改算法列表或选择结果，诱导双方使用弱算法、空加密或不启用完整性保护，这属于降级攻击。无线信道开放，中间人还可删除强算法、替换安全能力、伪造安全模式命令，使 UE 和网络对安全上下文理解不一致。

改进：算法能力、服务网身份、承载号、方向、随机数、计数器和最终算法选择必须纳入 MAC 或认证加密；安全模式命令应完整性保护，UE 验证通过后才开启安全上下文；禁止回退到已知弱算法；协商结果参与 KDF，防止中间人把一次协商结果挪到另一场会话。总结句：算法协商本身也是安全协议的一部分，必须认证和防篡改。

2. (10 分) 说明 WPA2/802.11i 中四次握手的作用。为什么说 AES-CCMP 比“单纯共享一个长期密码后直接加密”更安全？

对应章节/考点：第四讲 WLAN 安全；避开真题 WEP，改考 WPA2 四次握手、PTK/GTK、CCMP。

答案要点：

WPA2/802.11i 的目标是完成动态密钥建立和数据帧保护。认证可来自 802.1X/EAP 或 PSK，四次握手用 AP 的 ANonce、终端的 SNonce、双方 MAC 地址和主密钥材料派生 PTK，并分发或确认 GTK。PTK 可再分成加密、完整性、密钥确认等不同用途的子密钥。

它比长期共享密钥直接加密更安全：第一，每次连接有新的 nonce，密钥更有新鲜性；第二，PTK/GTK 分离，单播和组播密钥分开；第三，AES-CCMP 同时提供机密性、完整性和防重放；第四，密钥确认能证明双方确实掌握同一密钥；第五，用户离网或密钥泄露时更容易更新 GTK。若补充 WPA3，可写 SAE 抵抗离线字典攻击能力更强，前向安全更好。

3. (10 分) 请按“攻击过程”分析 GSM 伪基站为什么能诱导用户暴露 IMSI，并说明 3G/4G/5G 分别如何缓解。

对应章节/考点：第五讲 GSM 安全 + 第三讲无线威胁；避开真题安全域，改成攻击链分析。

答案要点：

GSM 的根本缺陷是单向认证：网络认证用户，但手机不认证网络。攻击过程可写为：攻击者搭建伪基站，广播更强信号或诱导重选；UE 接入后，伪基站请求身份；若 TMSI 不可用或被拒绝，UE 可能发送 IMSI；伪基站还可诱导关闭加密或使用弱算法，并通过位置更新实现跟踪。

缓解：3G/WCDMA 使用 AKA 双向认证，UE 通过 AUTN 中 MAC 和 SQN 验证网络，并增加信令完整性；4G 使用 EPS-AKA、GUTI/S-TMSI、NAS/AS 分层和安全模式完整性保护；5G 使用 SUPI/SUCI，用归属网公钥隐藏永久身份，并结合 5G-AKA、分层密钥、用户面完整性增强等机制。总结：从单向认证走向双向认证，从明文永久身份走向临时身份和公钥隐藏身份。

4. (10 分) WCDMA 中 f8 和 f9 分别解决什么安全问题？如果只启用 f8 加密而不启用 f9 完整性，会留下什么缺陷？

对应章节/考点：第七讲 WCDMA 安全；避开真题“每换基站是否重新认证”，改考 f8/f9。

答案要点：

WCDMA 中 f8 主要用于加密，保护空口数据机密性，使攻击者监听无线信道时不能直接获得明文。f9 主要用于完整性保护，给信令计算 MAC-I，使接收方能判断消息是否被篡改、伪造或重放。CK 通常用于加密相关处理，IK 用于完整性相关处理，体现密钥分离。

只启用 f8 不启用 f9 的缺陷是：攻击者虽然看不懂明文，但仍可能修改、插入、删除或重放信令，影响位置更新、承载建立、算法协商和切换等过程。控制信令一旦被篡改，可能造成降级、拒绝服务或错误安全上下文。改进：重要控制信令必须完整性保护，COUNT、方向、承载和消息内容应参与 MAC，接收端检查计数器和 MAC。

5. (10 分) TETRA 专网中，为什么端到端加密不能替代空口加密？请结合调度、组呼和网络管理场景说明。

对应章节/考点：第六讲 TETRA 安全；避开真题同步区别，改考保护范围和业务必要性。

答案要点：

端到端加密保护最终终端之间的业务内容，中间 SwMI 不能看到业务明文，适合公安、应急等高保密通信。但它不能替代空口加密，因为空口加密保护的是 MS 到基站/SwMI 的无线链路，除了业务内容，还包括部分控制、接入、调度、组呼控制和链路管理信息。

若只有端到端加密，没有空口加密，攻击者仍可在无线链路上分析或攻击控制信息，获取呼叫关系、组呼活动、终端接入行为，甚至干扰链路管理。TETRA 因此需要多层保护：空口加密防无线监听和链路攻击，端到端加密防网络内部或中间链路泄露业务内容，组密钥/CCK 等机制支持组呼业务。总结：空口加密是链路级安全，端到端加密是业务内容安全，二者保护对象不同。

6. (15 分) 说明 LTE 从接入请求到安全模式完成的大致安全建立过程。为什么要把 NAS 安全和 AS 安全分开？

对应章节/考点：第八讲 LTE 安全；避开真题前向/后向安全，改考安全连接建立流程。

答案要点：

LTE 安全建立可按流程写：UE 发起接入请求；MME 与归属网完成 EPS-AKA，产生 CK/IK 并派生 K_{ASME} ；NAS 层建立 UE 与 MME 之间的 NAS 加密和完整性密钥；随后派生

K_{eNB} ，由 eNB 建立 AS 安全；RRC 信令使用 K_{RRCenc} 、 K_{RRCint} ，用户面使用 K_{UPenc} ，部分场景用户面完整性未强制启用。

NAS/AS 分开的原因：MME 属于核心网控制节点，eNB 数量多、部署分散、相对不完全可信。NAS 安全保护 UE-MME 的核心网控制信令；AS 安全保护 UE-eNB 的无线接入层信令和用户面。这样 eNB 只掌握接入层密钥，不掌握 NAS 密钥，减少单个 eNB 被攻破后的影响。答题结论：LTE 的分层密钥管理体现了密钥隔离、最小授权和分层防护。

7. (15 分) 5G 网络切片为什么需要二次认证？SBA 和 SEPP 分别带来什么新的安全要求？

对应章节/考点：5G 网络安全；避开真题 SUPI/SUCI 匿名，改考切片、SBA、SEPP。

答案要点：

5G 主认证只能证明 UE 是合法移动用户，不一定证明它有权访问某个行业切片。切片可能承载电力、车联网、工业控制、医疗等业务，安全等级和准入条件不同，所以需要切片二次认证，实现切片级访问控制、最小权限和业务隔离。

SBA 是服务化核心网，网元像 API 一样相互调用，因此需要 TLS、OAuth/令牌、服务发现安全、接口访问控制、日志审计和异常检测，防止 API 滥用、越权调用和横向移动。SEPP 保护运营商之间的漫游边界，解决跨 PLMN 信令的完整性、机密性、拓扑隐藏和边界过滤问题。总结：5G 安全不只是空口加密，还包括切片隔离、服务化接口安全和运营商互联边界安全。

8. (20 分) 某工业无线控制系统要求低时延和高可靠，只打算“预共享密钥 + 加密数据”，不做双向认证、完整性保护和密钥更新。请设计更完整的安全方案。

对应章节/考点：综合设计题；避开真题 AES-CBC 具体方案，改成工业无线接入安全设计。

答案要点：

先评价缺陷：预共享密钥加密只能提供有限机密性，不能证明对方身份，不能防伪基站/假终端，不能防篡改和重放；长期同一密钥会扩大泄露影响；工业控制对完整性和新鲜性要求很高，旧指令重放可能造成严重后果。

方案可按步骤写：第一，身份保护，终端使用临时身份或公钥隐藏永久身份，不在空口暴露长期身份。第二，双向认证，采用 AKA 或证书/PSK 认证，让终端认证网络，网络认证终端，认证消息包含随机数和序列号。第三，KDF 派生会话密钥，区分加密密钥、完整性密钥、上下行方向、控制信令和用户数据。第四，数据保护使用 AES-GCM/CCM 等认证加密；若低时延要求高，可选择硬件支持的 AEAD。第五，每条报文带 COUNT/Seq、方向、承载号和 Nonce，接收端维护重放窗口。第六，密钥在重认证、切换、计数器接近上限或策略触发时更新。最后总结：工业无线不能只追求加密，还要同时保证认证、完整性、新鲜性和密钥生命周期管理。

模拟题 B：综合押题卷

1. (10 分) 某协议把“是否启用完整性保护”作为普通明文字段发送。攻击者若把该字段改成“不启用”，会造成什么问题？

对应章节/考点：第二/三讲；考完整性保护的必要性和降级攻击。

答案要点：

这是典型安全能力降级。攻击者篡改明文字段，使双方关闭完整性保护，后续消息即使加密也可能被插入、删除、替换或重放。更严重的是，接收方以为这是合法协商结果，从而建立弱安全上下文。改进：安全能力、算法列表、完整性开关、双方身份、随机数和最终选择结果必须纳入 MAC/认证加密；安全模式命令必须完整性保护；协议应禁止协商到不满足策略的弱配置。

2. (10 分) 比较 WPA2-PSK 与 WPA3-SAE 在口令安全上的差异。为什么 SAE 更适合抵抗离线字典攻击？

对应章节/考点：第四讲 WLAN 安全；考 WPA3/SAE，减少与 WEP 真题重合。

答案要点：

WPA2-PSK 使用预共享口令，攻击者如果抓到四次握手报文，可能离线尝试大量口令并验证猜测是否正确，因此弱口令风险较大。WPA3-SAE 使用同时认证等价交换，口令不直接变成可被离线验证的材料，每次交互有新的随机性，并能提供更好的前向安全。

SAE 的优势：抵抗离线字典攻击能力更强；即使一次会话密钥泄露，也不应直接影响过去会话；减少弱口令被抓包后长期离线破解的风险。仍需注意：弱口令本身仍不可取，设备实现、降级到 WPA2、管理帧保护和用户配置也会影响实际安全。

3. (10 分) TMSI/GUTI 这类临时身份能否彻底解决用户跟踪问题？请分析原因。

对应章节/考点：GSM/LTE/5G 身份隐私；考临时身份局限，不直接重复 5G SUCI 真题。

答案要点：

临时身份能降低永久身份暴露概率，但不能彻底解决跟踪。原因：首次接入、临时身份丢失、重分配失败或伪基站请求身份时，终端可能暴露 IMSI/SUPI；如果临时身份更新不及时，同一临时身份仍可被长期关联；寻呼、位置更新、业务行为、无线指纹和错误消息差异也可能造成可链接性。

改进：在安全上下文建立后及时更新临时身份；避免空口明文发送永久身份；5G 使用 SUCI 对 SUPI 做公钥随机化隐藏；统一错误消息，减少通过失败原因识别用户；寻呼和重同步流程也应考虑隐私保护。

4. (10 分) WCDMA AKA 中 UE 为什么要检查 AUTN 中的 MAC 和 SQN? 如果只检查 MAC 不检查 SQN 会怎样?

对应章节/考点: 第七讲 WCDMA 安全; 考 AUTN 细节, 不重复“每换基站重新认证”。

答案要点:

MAC 用于证明 AUTN 来自掌握长期密钥的归属网, 帮助 UE 认证网络, 防止伪网络伪造认证令牌。SQN 用于判断认证向量是否新鲜, 防止攻击者重放旧的 RAND/AUTN。AK 可用于隐藏 SQN, 减少隐私泄露。

如果只检查 MAC 不检查 SQN, 旧的合法 AUTN 仍可能被重放。虽然攻击者不知道长期密钥, 但可以截获历史合法认证材料并再次发送, 造成重放、同步异常或拒绝服务。正确做法是同时检查 MAC 和 SQN: MAC 保证来源合法, SQN 保证消息新鲜。

5. (10 分) TETRA 组呼业务中, 为什么需要考虑组密钥管理? 组成员变化会带来什么安全问题?

对应章节/考点: 第六讲 TETRA 安全; 考组呼和密钥更新, 不直接问空口/端到端同步。

答案要点:

TETRA 常用于专网组呼, 一个组内多个终端需要共享组通信能力, 因此要有组密钥或通用密钥支持组业务。问题是组成员会变化: 新成员加入时, 不应能解密加入前的历史通信; 旧成员离开后, 不应继续解密未来通信。这分别对应后向/前向意义上的组密钥安全。

改进: 组成员变化、终端丢失、权限撤销或安全策略触发时, 应更新组密钥; 密钥分发要经过认证和完整性保护; 不同组、不同业务、不同安全等级应使用不同密钥; 空口加密和端到端加密要根据业务保密要求配合使用。

6. (15 分) 为什么说 LTE 用户面完整性保护不足是一个安全缺口? 5G 在哪些场景下更需要开启用户面完整性?

对应章节/考点: 第八讲 LTE + 5G 改进; 考用户面完整性, 不重复 LTE 前向/后向真题。

答案要点:

LTE 中 NAS 和 RRC 信令通常有完整性保护, 但用户面完整性往往可选或未开启。加密只能防窃听, 不能防篡改。攻击者即使看不懂密文, 也可能修改、插入、删除或重放用户面数据, 造成 DNS 欺骗、数据注入、重定向或业务异常。

5G 支持用户面完整性保护, 尤其在工业控制、车联网、电网、医疗、远程控制、专网切片等高安全场景更重要。实现上可使用认证加密或独立 MAC, 把方向、承载、COUNT/序列号、Nonce、密文和必要上下文纳入认证标签; 接收端检查重放窗口。结论: 用户面安全不能只看机密性, 高价值业务必须重视完整性和新鲜性。

7. (15 分) 5G 服务化核心网中, 若某网络功能 NF 的 API 鉴权配置错误, 可能造成哪些风险? 应如何防护?

对应章节/考点: 5G SBA 安全; 考服务化架构 API 风险。

答案要点:

SBA 中网络功能通过服务接口互相调用, 类似 API 化核心网。若 API 鉴权配置错误, 可能出现越权调用、伪造 NF、非法获取用户上下文、滥用注册发现、横向移动、敏感信息泄露和拒绝服务等风险。攻击面从传统信令链路扩展到服务接口、令牌、服务发现和日志审计。

防护: NF 之间使用 TLS 保护机密性和完整性; 使用 OAuth/令牌和细粒度授权控制服务调用; 服务发现和注册要认证; 按最小权限配置 API; 对异常调用、频繁失败、越权访问做日志审计和检测; 跨运营商边界通过 SEPP 做过滤、拓扑隐藏和完整性保护。总结: 5G 核心网安全从“网元信令安全”扩展到“API 服务安全”。

8. (20 分) 某无线系统准备把“身份、算法、序列号、密文”分别独立处理: 身份明文发、算法明文协商、序列号不认证、数据只加密。请从安全目标角度整体评价并重构报文保护格式。

对应章节/考点: 综合分析题; 考通用模板, 避开去年 AES-CBC 原题。

答案要点:

整体评价: 身份明文发送会造成 IMSI/SUPI 类永久身份泄露和位置跟踪; 算法明文协商会被降级; 序列号不认证会被篡改或重放; 数据只加密不完整性, 攻击者可改密文、插入或删除报文; 各字段独立处理, 没有绑定到同一安全上下文, 容易出现跨会话、跨方向、跨承载攻击。

重构方案: 身份阶段使用临时身份或 SUCI 类隐藏身份; 认证阶段完成双向认证和密钥协商; 用 KDF 派生加密密钥、完整性密钥、上下行方向密钥和不同承载密钥; 报文使用 AEAD 或 Encrypt-then-MAC。推荐格式可写:

$$Header = (ID_{temp}, Alg, Dir, Bearer, Seq, Nonce),$$

$$C = Enc_{K_{enc}}(Nonce, P), \quad T = MAC_{K_{int}}(Header, C).$$

接收方先检查身份上下文、算法、Seq/重放窗口和 MAC, 再解密。密钥在重认证、切换、计数器接近上限或策略触发时更新。总结: 安全设计要把身份隐私、算法协商、完整性、防重放和密钥分离绑定起来, 而不是把字段孤立处理。

模拟题 C：真题同章换问法卷

1. (10 分) 在无线认证协议中，为什么仅依靠“用户名 + 固定口令/固定响应值”容易受到重放攻击？请给出三类防护办法。

对应章节/考点：对应去年第 1 题：第二/三讲，仍考防重放，但换成认证协议场景。

答案要点：

固定口令或固定响应值的问题是每次认证消息相同或可预测。攻击者在无线信道中截获一次合法认证消息后，可以在之后重新发送，接收方若无法判断消息新旧，就可能把旧消息当作新的合法认证接受。这就是重放攻击，本质是缺少新鲜性检查。

三类防护办法：第一，随机数挑战-应答。网络每次发送 RAND/nonce，终端响应必须绑定本次随机数，旧响应无法通过新挑战。第二，序列号或计数器。消息中加入 SQN、COUNT 或 Seq，并纳入 MAC，接收端拒绝重复、过旧或异常乱序消息。第三，时间戳或有效期。消息带时间窗口，超时拒绝。最后要写：随机数、序列号、时间戳本身也必须被 MAC、签名或认证加密保护，否则攻击者可以篡改这些字段。

2. (10 分) 某 WLAN 方案使用 RC4 流密码和 CRC 校验，并把 IV 明文放在数据帧中。请评价其安全性，并说明应如何改进。

对应章节/考点：对应去年第 2 题：第四讲 WLAN，仍考 WEP 原理缺陷，但不直接问“WEP 功能原理”。

答案要点：

该方案本质上类似 WEP。RC4 是流密码，发送端用 IV 和共享密钥生成密钥流，再与明文异或得到密文；CRC 用于产生校验值，接收端解密后重新计算 CRC 判断传输错误。IV 明文发送本身不一定错误，但 IV 必须足够长、不能重复，并且关键字段应被完整性保护。

缺陷：第一，若 IV 过短或重复，同一密钥流可能被多次使用，流密码密钥流复用会泄露明文关系。第二，CRC 不是带密钥的 MAC，只能检错，不能防恶意篡改。第三，长期静态共享密钥难以管理，一个用户泄露会影响整个网络。第四，若共享密钥认证暴露明文和密文关系，还可能帮助攻击者恢复密钥流。改进应使用 WPA2/802.11i 或 WPA3：通过 802.1X/EAP 或 SAE/PSK 完成认证，用四次握手派生 PTK/GTK，使用 AES-CCMP 或更强机制同时提供机密性、完整性和防重放。

3. (10 分) 从移动通信安全体系看，用户域安全和接入域安全有什么区别？请以 PIN 认证和 AKA 认证为例说明。

对应章节/考点：对应去年第 3 题：第三讲安全域，仍考 PIN 与接入认证是否同域。

答案要点：

用户域安全主要保护用户、终端和 SIM/USIM 之间的本地使用安全，解决“拿到这张卡或这个终端的人是否有权使用”的问题。PIN 认证就是用户域安全，通常在本地完成，参与实体主要是用户、终端和 SIM/USIM。

接入域安全主要保护 UE 通过无线空口接入移动网络的过程,解决“用户是否合法、网络是否合法、双方如何协商会话密钥、空口如何加密和完整性保护”的问题。GSM 鉴权、WCDMA AKA、LTE EPS-AKA、5G-AKA 都属于接入域。AKA 中网络验证用户,UE 也可通过 AUTN 等机制验证网络,并产生后续加密和完整性密钥。结论:PIN 和 AKA 都叫认证,但安全目标、参与实体和保护范围不同;PIN 属于用户域,AKA 属于接入域。

4. (10 分) WCDMA 中 UE 如何通过 AUTN 验证网络?为什么安全上下文失效或跨服务区移动时需要重新建立安全?

对应章节/考点: 对应去年第 4 题:第七讲 WCDMA,仍考 AKA 与切换安全上下文。

答案要点:

WCDMA AKA 的认证向量为 $AV = (RAND, XRES, CK, IK, AUTN)$ 。网络向 UE 发送 RAND 和 AUTN,UE 用 USIM 中的长期密钥计算并检查 AUTN 中的 MAC 和 SQN。MAC 正确说明该认证令牌来自掌握长期密钥的归属网,从而帮助 UE 认证网络;SQN 合理说明认证向量是新的,不是旧消息重放。认证成功后,双方得到 CK 和 IK,分别用于加密和完整性保护。

安全上下文失效、跨服务区移动或无法可信转移上下文时,需要重新认证或重新建立安全上下文。原因是新接入点或新服务网必须被确认合法,旧密钥不能长期复用,加密和完整性保护要连续有效,也要防止旧认证向量、旧密钥或旧上下文被重放和滥用。稳妥说法:不是每换一个基站都必定完整 AKA;若上下文仍有效且可安全转移,可以复用或派生;若跨域、过期、策略要求或上下文不可信,则应重新认证或更新。

5. (10 分) TETRA 中空口加密和端到端加密都可能使用密钥流。为什么二者的同步对象不同?

对应章节/考点: 对应去年第 5 题:第六讲 TETRA,仍考空口/端到端密钥流同步。

答案要点:

空口加密保护 MS 到基站/SwMI 之间的无线链路,加密终结点是终端和网络接入侧。它的同步对象是 MS 与 SwMI/基站,通常依赖空口帧号、时隙、IV、系统同步信息等,使链路两端的 KSG 生成相同密钥流。网络参与空口加密,所以切换、重选和链路建立时可由网络帮助维护同步。

端到端加密保护最终终端之间的业务内容,中间网络只转发密文,不应掌握业务明文和端到端密钥。它的同步对象是两个最终通信终端,因此不能只依赖某一段空口帧号,而要通过同步帧、SV、Key ID、端到端计数等信息,让接收终端知道使用哪把端到端密钥、从哪个同步值开始生成密钥流。总结:空口同步是“终端-网络”的链路同步,端到端同步是“终端-终端”的业务同步。

6. (15 分) 5G 为什么要用 SUCI 隐藏 SUPI? 请说明基本流程, 并分析它能解决什么问题、不能解决什么问题。

对应章节/考点: 对应去年第 6 题: 5G 网络安全, 仍考 SUPI/SUCI 匿名。

答案要点:

SUPI 是 5G 用户永久身份, 类似以前的 IMSI。若永久身份在空口明文发送, 攻击者可以监听、诱导上报并长期跟踪用户。5G 使用 SUCI 隐藏 SUPI: UE/USIM 使用归属网公钥对 SUPI 进行随机化加密, 生成 SUCI; 空口发送 SUCI; 归属网 SIDF 用私钥恢复 SUPI。随机化很重要, 同一 SUPI 多次生成的 SUCI 应不同, 否则仍可被链接。

它能解决的问题: 减少永久身份明文暴露, 缓解 IMSI catcher/伪基站诱导身份泄露; 降低同一用户多次接入的可链接性; 首次接入或没有临时身份时也能隐藏永久身份; 与 5G-AKA、AUSF/SEAF、分层密钥结合, 增强身份保护和认证安全。

不能解决的问题: SUCI 不是完全匿名。服务网和归属网仍需合法识别用户; 寻呼、位置更新、业务模式、无线指纹、错误消息差异、SQN 重同步等仍可能造成关联; 归属网公钥配置错误、随机数质量差或实现缺陷也会影响安全。因此 SUCI 是“对空口攻击者隐藏永久身份”, 不是对所有网络实体绝对匿名。

7. (15 分) LTE 为什么采用分层密钥管理? 请说明 K_{ASME}、NAS 密钥、K_{eNB} 与切换密钥更新的关系。

对应章节/考点: 对应去年第 7 题: 第八讲 LTE, 仍考密钥管理和前向/后向安全。

答案要点:

LTE 中 eNB 数量多、部署分散, 属于不完全可信节点, 因此不能让 eNB 掌握所有安全密钥。LTE 采用分层密钥管理, 大致关系为

$$K \rightarrow CK/IK \rightarrow K_{ASME} \rightarrow K_{NASenc}, K_{NASint}, K_{eNB} \rightarrow K_{RRC}, K_{UP}.$$

K 是 USIM 与归属网共享的长期密钥; CK/IK 来自 AKA; K_{ASME} 是 EPS 安全锚密钥; NAS 密钥保护 UE 与 MME 之间的 NAS 信令; K_{eNB} 及下级 RRC/UP 密钥保护 UE 与 eNB 之间的接入层信令和用户面。这样实现 NAS/AS 分离和密钥隔离, eNB 只掌握接入层密钥。

切换时若直接复用旧 K_{eNB} , 目标 eNB 可能知道历史通信, 源 eNB 也可能知道未来通信, 影响后向安全和前向安全。因此 LTE 使用 KDF、目标小区参数、 K_{eNB}^* 、NH/NCC 等机制派生目标基站密钥。结论要稳: LTE 的分层密钥和 NH/NCC 能增强切换中的前向/后向安全, 但是否完全满足取决于切换方式和上下文处理; 直接转发旧密钥是不安全的。

8. (20 分) 某方案使用 AES-CBC 加密无线数据, IV 明文随密文发送, 双方密钥由线下安全方式预先配置。请从机密性、完整性、防重放和密钥管理角度评价, 并给出改进方案。

对应章节/考点: 对应去年第 8 题: 第二讲密码基础 + 综合分析, 仍考 CBC/IV/完整性/防重放。

答案要点：

先评价优点：AES 是标准分组密码；CBC 比 ECB 更好，相同明文块不会直接产生相同密文块；密钥线下安全配置可以避免密钥在开放无线信道中明文传输。如果 IV 随机、不可预测且不重复，CBC 能提供基本机密性。

主要缺陷：第一，CBC 只提供机密性，不提供完整性和来源认证。攻击者看不懂明文，但可以修改 IV 或密文块，使解密后的明文发生变化。第二，IV 明文发送可以，但必须保证随机不重复，并且应被完整性保护；修改 IV 会影响第一块明文。第三，若没有序列号、COUNT、nonce 或时间窗口，旧的 $IV \parallel C$ 可以被重放。第四，长期预配置同一密钥会扩大泄露影响；若同一密钥同时用于加密、完整性、上下行或不同业务，会出现一钥多用问题。第五，CBC 若错误提示不统一，可能有填充 oracle 风险。

改进方案：优先使用 AES-GCM、AES-CCM 等认证加密；若必须保留 CBC，应采用 Encrypt-then-MAC，如

$$C = AES\text{-}CBC_{K_{enc}}(IV, P), \quad T = MAC_{K_{int}}(ID_A, ID_B, Alg, Dir, Bearer, Seq, IV, C).$$

接收方先检查 MAC 和 Seq/重放窗口，再解密。用 KDF 从主密钥派生 K_{enc} 、 K_{int} 、上下行方向密钥和不同承载密钥；IV/Nonce 不重复；计数器接近上限、切换、重认证或策略触发时更新密钥。总结：安全通信不能只写“用了 AES”，还要同时满足完整性、认证、新鲜性和密钥生命周期管理。